

NanoAudit - Reporte Tecnico

INFORME TECNICO DE AUDITORIA

=====

Auditor: Ing.Ángel G. Castillo G.

Fecha: 2026-02-02 16:30:20

Modulo: Auditoria Red

=====

INFORME DE AUDITORIA DE RED - CONSULTOR SENIOR EN CIBERSEGURIDAD

Fecha: 2023-10-27

1. ANALISIS TECNICO: Que se encontro.

Se realizo una auditoria de red que revelo la presencia de multiples puertos abiertos en el sistema o dispositivo objetivo. Los hallazgos principales son los siguientes:

- Port 21 (FTP): Abierto. No se identifico el servicio especifico, pero se asume un servidor FTP.
- Port 22 (SSH): Abierto. No se identifico el servicio especifico, pero se asume un servidor SSH.
- Port 23 (Telnet): Abierto. No se identifico el servicio especifico, pero se asume un servidor Telnet.
- Port 80 (HTTP): Abierto, ejecutando "Boa HTTPd 0.94.13". Esta es una version extremadamente antigua del servidor web Boa.
- Port 161 (SNMP): Abierto. No se identifico el servicio especifico, pero se asume un agente SNMP.
- Port 443 (HTTPS): Abierto. No se identifico el servicio especifico, pero se asume un servidor web seguro (HTTPS).

NanoAudit - Reporte Tecnico

- Port 631 (CUPS/IPP): Abierto. No se identifico el servicio especifico, pero se asume un servicio de impresion (CUPS o IPP).
- Port 9100 (Printer Raw): Abierto. No se identifico el servicio especifico, pero se asume un servicio de impresion directa.

La presencia de multiples puertos abiertos aumenta la superficie de ataque del sistema. La identificacion de "Boa HTTPd 0.94.13" en el puerto 80 es una preocupacion critica debido a la antiguedad y las conocidas vulnerabilidades de esta version de software. La falta de identificacion de versiones para otros servicios abiertos sugiere que se requiere un escaneo mas profundo (con deteccion de versiones) para una evaluacion completa.

2. IMPACTO: Riesgo para el negocio.

La configuracion actual representa un riesgo significativo para la seguridad y continuidad del negocio:

- Alto Riesgo de Compromiso de Sistema (Port 80 - Boa HTTPd 0.94.13): La version identificada de Boa HTTPd es obsoleta (lanzada hace mas de una decada) y es altamente probable que contenga multiples vulnerabilidades conocidas y criticas, incluyendo ejecucion remota de codigo (RCE), desbordamientos de buffer, y divulgacion de informacion. Un atacante podria explotar estas vulnerabilidades para obtener control total del sistema, defacing del sitio web, inyeccion de malware, o acceder a datos sensibles. Esto podria resultar en perdida de datos, interrupcion de servicio, danos a la reputacion y multas por incumplimiento normativo.

NanoAudit - Reporte Tecnico

- Riesgo de Credenciales en Claro y Acceso No Autorizado (Port 23 - Telnet): Telnet transmite datos y credenciales en texto plano, lo que facilita la intercepcion por parte de un atacante. Si hay un servicio Telnet habilitado, se corre el riesgo de robo de credenciales, lo que podria llevar a un acceso no autorizado a otros sistemas y recursos, resultando en violaciones de datos o control completo del sistema.
- Riesgo de Ataques de Fuerza Bruta y Compromiso de Cuentas (Port 21 - FTP, Port 22 - SSH): Aunque SSH es mas seguro que Telnet, y FTP puede serlo con configuraciones adecuadas (FTPS/SFTP), la exposicion de estos puertos los hace vulnerables a ataques de fuerza bruta o de diccionario para adivinar credenciales. Un compromiso podria otorgar acceso a archivos sensibles o al sistema.
- Riesgo de Divulgacion de Informacion y Denegacion de Servicio (Port 161 - SNMP, Port 631 - CUPS/IPP, Port 9100 - Printer Raw):
 - SNMP (v1/v2c) puede divulgar informacion detallada sobre la infraestructura de red, configuraciones de dispositivos y estado del sistema si se utilizan cadenas de comunidad debiles o por defecto.
 - Los servicios de impresion (CUPS/IPP, Port 9100) pueden ser explotados para ataques de denegacion de servicio (DoS) inundando impresoras con trabajos o, en casos mas avanzados, explotar vulnerabilidades de software para lograr ejecucion de codigo o acceso a datos de impresion.

En resumen, la multiplicidad de puertos abiertos, especialmente con un servidor web obsoleto y el uso de Telnet, crea una superficie de ataque excesivamente amplia y critica, exponiendo la organizacion a riesgos inminentes de violacion de datos, interrupcion de operaciones y danos economicos y reputacionales severos.

3. SOLUCION: Comandos o pasos de mitigacion.

NanoAudit - Reporte Tecnico

Se recomienda tomar las siguientes acciones inmediatas y a mediano plazo para mitigar los riesgos identificados:

Acciones Inmediatas y Criticas:

1. DESHABILITAR O REEMPLAZAR SERVIDOR WEB OBSOLETO (Port 80 - Boa HTTPd 0.94.13):

- * Accion: Evaluar la necesidad de este servicio. Si no es esencial, deshabilitarlo inmediatamente. Si es necesario, se DEBE migrar a un servidor web moderno y soportado (ej. Nginx, Apache HTTP Server, Caddy) o colocarlo detras de un proxy inverso/WAF con reglas estrictas. No hay comandos de "actualizacion" para esta version; es un reemplazo completo.

- * Pasos (si se decide deshabilitar y se asume un sistema Linux basado en systemd):

```
sudo systemctl disable <nombre_servicio_boa>
```

```
sudo systemctl stop <nombre_servicio_boa>
```

(Requerira identificar el nombre exacto del servicio o proceso de Boa)

2. DESHABILITAR TELNET (Port 23):

- * Accion: Telnet es un protocolo inherentemente inseguro. Debe ser deshabilitado en todos los sistemas.

Use SSH para acceso remoto seguro.

- * Comandos (asumiendo un sistema Linux basado en systemd):

```
sudo systemctl disable telnet.socket
```

```
sudo systemctl stop telnet.socket
```

(En algunos sistemas mas antiguos, podria ser un servicio xinetd o similar, que se deberia deshabilitar/desinstalar).

NanoAudit - Reporte Tecnico

Acciones de Alta Prioridad:

3. ASEGURAR SSH (Port 22):

- * Accion: Si SSH es necesario, configurarlo de forma segura.
- * Pasos:
 - * Deshabilitar el acceso de root via SSH: Editar `/etc/ssh/sshd_config` y configurar `PermitRootLogin no``.
 - * Usar autenticacion basada en claves (public-key authentication) en lugar de contraseñas.
 - * Aplicar politicas de contraseñas fuertes si se permite la autenticacion con contraseña.
 - * Configurar herramientas como Fail2ban para bloquear IPs con intentos fallidos.
 - * Considerar cambiar el puerto SSH predeterminado (aunque esto no es una medida de seguridad fuerte, reduce el ruido de los bots).
- * Mantener el servidor SSH actualizado.

4. ASEGURAR FTP (Port 21):

- * Accion: Si FTP es necesario, configurarlo de forma segura o migrar a SFTP/FTPS.
- * Pasos:
 - * Usar FTPS (FTP sobre SSL/TLS) o SFTP (SSH File Transfer Protocol) en lugar de FTP plano.
 - * Aplicar politicas de contraseñas fuertes.
 - * Limitar el acceso a directorios especificos (chroot jails).
 - * Deshabilitar el acceso anonimo a menos que sea estrictamente necesario.
 - * Mantener el servidor FTP actualizado.
 - * Si no es necesario, deshabilitar el servicio FTP.

5. ASEGURAR O DESHABILITAR SNMP (Port 161):

NanoAudit - Reporte Tecnico

- * Accion: Si SNMP es necesario, configurar SNMPv3 con autenticacion y cifrado. Si no, deshabilitarlo.

- * Pasos:

- * Migrar a SNMPv3.

- * Restringir el acceso SNMP a direcciones IP especificas y confiables en el firewall.

- * Cambiar las cadenas de comunidad por defecto (public/private) por unas complejas si se usa SNMPv1/v2c.

- * Si no se usa, deshabilitar el servicio SNMP.

6. ASEGURAR HTTPS (Port 443):

- * Accion: Aunque HTTPS es mas seguro que HTTP, requiere una configuracion robusta.

- * Pasos:

- * Asegurarse de que se utilizan versiones TLS modernas (minimo TLS 1.2, preferiblemente TLS 1.3).

- * Usar cifrados fuertes y deshabilitar los debiles.

- * Implementar HSTS (HTTP Strict Transport Security).

- * Utilizar certificados SSL/TLS validos de una autoridad de certificacion confiable.

- * Mantener el servidor web/aplicacion y librerias SSL/TLS actualizados.

7. RESTRINGIR O DESHABILITAR SERVICIOS DE IMPRESION (Port 631 - CUPS/IPP, Port 9100 - Printer Raw):

- * Accion: Estos puertos no deberian estar accesibles desde la red externa o en segmentos de red donde no sea estrictamente necesario.

- * Pasos:

- * Restringir el acceso a estos puertos unicamente a las direcciones IP de los hosts autorizados para imprimir o administrar impresoras, utilizando reglas de firewall.

- * Si no hay impresoras de red o no se requiere acceso remoto a la gestion de impresion, deshabilitar

NanoAudit - Reporte Tecnico

estos servicios.

- * (Para CUPS) Editar `/etc/cups/cupsd.conf` para configurar `Listen` a localhost o IPs especificas, y `Allow` para restringir el acceso.

- * (Para Port 9100) Desactivar la funcion "raw printing" en la configuracion de la impresora o el servidor de impresion si es posible.

Acciones Generales y de Mejora Continua:

- Firewall: Implementar un firewall de perimetro y/o host para permitir unicamente el trafico necesario y bloquear el resto.
- Principio de Menor Privilegio: Asegurarse de que todos los servicios se ejecuten con los privilegios minimos necesarios.
- Parches y Actualizaciones: Establecer una politica robusta de gestion de parches para mantener todos los sistemas operativos y aplicaciones actualizados.
- Segmentacion de Red: Segmentar la red para aislar sistemas con diferentes niveles de riesgo y reducir el impacto de un posible compromiso.
- Auditorias Regulares: Realizar auditorias de seguridad y escaneos de vulnerabilidades de forma regular para identificar y abordar nuevas exposiciones.
- Deteccion de Intrusiones: Implementar sistemas de deteccion/prevencion de intrusiones (IDS/IPS) para monitorear y alertar sobre actividades sospechosas.

La implementacion de estas medidas es crucial para proteger los activos de la organizacion contra amenazas ciberneticas.

=====